

Datenschutzbericht — Fräsdienst-Service E. Feind GmbH

Domain: fraesdienst-feind.de

Berichtstyp: Zusammenfassender Datenschutz-/DSGVO-Statusbericht mit Maßnahmen, Vorlagen und Roadmap

Zielgruppe: Geschäftsführung, Datenschutzbeauftragte(r) (intern/extern), IT-Verantwortliche, ggf. Aufsichtsbehörde (LDI NRW)

Erstellt von: David Halko (Marketing & Eventmanagement) mit KI-Unterstützung

Berichtsdatum: 14.09.2026

Version: 1.0 (Entwurf)

Vertraulichkeit: Streng vertraulich — nur zur internen Verwendung

Rechtlicher Hinweis / Haftungsausschluss: Dieser Bericht ist eine praxisorientierte fachliche Aufbereitung des Datenschutz-Status und **keine Rechtsberatung**. Er ersetzt weder die Prüfung durch einen Datenschutzbeauftragten noch durch einen Fachanwalt für IT-/Datenschutzrecht. Alle enthaltenen Muster (Datenschutzerklärung, AVV-Klauseln, Einwilligungen, Meldevorlagen, Antwortschreiben) sind Textbausteine, die vor produktivem Einsatz rechtlich zu prüfen und an die tatsächlichen Verhältnisse anzupassen sind. Bei rechtlichen oder vertraglichen Fragen gilt durchgängig: „**Bitte Rechtsabteilung / Fachanwalt für IT-Recht prüfen.**“

Hinweis zur Faktenlage: Dieser Bericht kombiniert **verifizierte Fakten** (aus der internen SEO-/Lead-Reporting-Codebasis der Firma) mit **klar gekennzeichneten Annahmen** (branchenüblich, mangels vollständiger Information). Ein geplanter Live-Abruf der Website fraesdienst-feind.de war in der Arbeitsumgebung technisch **nicht möglich** (Netzwerk-Egress gesperrt); alle rein webseitenbezogenen Aussagen sind daher als Annahme markiert und in den offenen Fragen mit **hoher Priorität** zur Verifizierung aufgeführt. Jede Annahme ist im **Annahmenverzeichnis (Anhang M)** zentral gelistet.

Inhaltsverzeichnis

1. Executive Summary
2. Unternehmens- und Tätigkeitsbeschreibung
3. Rechtsgrundlagen & Compliance-Check
4. Dateninventar & Verzeichnis der Verarbeitungstätigkeiten (VVT)
5. Datenflussanalyse (Data Flow Mapping)
6. Technische und organisatorische Maßnahmen (TOM)
7. Drittanbieter, Auftragsverarbeitung & Verträge
8. Datenschutz-Folgenabschätzung (DPIA)
9. Datensicherheit & Vorfalldmanagement
10. Betroffenenrechte & Prozesse
11. Einwilligungen, Informationspflichten & Datenschutzerklärung
12. Spezifische Prüfung Web/Online-Tools
13. Mitarbeiter, Schulung & Rollen
14. Risikoanalyse & Priorisierung
15. Audit- & Monitoringplan
16. Antworten auf den Fragen-Katalog
17. Offene Fragen (priorisiert)
18. Anhänge & Vorlagen

1. Executive Summary

Die Fräsdienst-Service E. Feind GmbH verarbeitet als B2B-Fertigungsbetrieb (CNC-Fräsen / Lohnfertigung) überwiegend Kunden-, Auftrags-, Lieferanten- und Beschäftigtendaten sowie Website-Besucherdaten. Das Datenschutzniveau ist in Teilbereichen bereits solide (z. B. DSGVO-bewusste Trennung von Rohdaten und Code, kein Verkauf von Daten, überschaubare Verarbeitungslandschaft), es fehlen jedoch **zentrale Pflichtdokumente und Nachweise**.

Größte Risiken (Kurzfassung):

1. **Website-Tracking ohne rechtssicheres Consent (hoch).** Google Analytics 4 ist nachweislich im Einsatz. Ohne vorheriges Opt-in per Consent-Banner (§ 25 TDDDG) und ohne aktuelle Datenschutzerklärung drohen Abmahnungen und Bußgelder.
2. **Fehlendes/unvollständiges Verzeichnis der Verarbeitungstätigkeiten (Art. 30) und fehlende AV-Verträge (Art. 28) (hoch).** Für Google, Hosting, ggf. Steuerberater/Lohn und IT-Support müssen AVV vorliegen.
3. **US-Datentransfer (mittel-hoch).** Google-Dienste übermitteln Daten in die USA; die Rechtsgrundlage (EU-US Data Privacy Framework) ist dokumentierbar, muss aber sauber belegt werden.

4. **Fehlendes Löschkonzept & TOM-Dokumentation (mittel).** Aufbewahrungs- und Löschfristen sind nicht formalisiert; TOM nach Art. 32 sind nicht dokumentiert.
5. **Fehlender Prozess für Betroffenenrechte und Datenpannen (mittel).** Kein dokumentiertes Verfahren für Auskunft/Löschung und keine 72-Stunden-Meldeketten (Art. 33/34).

Top-priorisierte Sofortmaßnahmen (0–3 Monate): Consent-Management-Banner mit Opt-in vor GA4 aktivieren; Datenschutzerklärung und Impressum aktualisieren; VVT erstellen; AV-Verträge einholen/prüfen; Löschkonzept und Datenpannen-Meldeprozess einführen; klären, ob ein DSB zu benennen ist.

Mit überschaubarem Aufwand (im Wesentlichen Dokumentation, Konfiguration und Schulung; nur geringe Softwarekosten) lässt sich innerhalb von 12 Monaten ein belastbares DSGVO-Konformitätsniveau erreichen. Der beigefügte **To-Do-Plan (Anhang K)**, das **Risiko-Dashboard (Anhang O)** und die **12-Monats-Roadmap (Anhang N)** liefern die konkrete Umsetzung mit Verantwortlichkeiten und Fristen.

(Executive Summary: ~250 Wörter)

2. Unternehmens- und Tätigkeitsbeschreibung

2.1 Kurzprofil (Fakten + Annahmen)

Verifiziert (aus interner Codebasis): Die Firma tritt als „E. Feind GmbH“ / „Fräsdienst Feind“ auf und betreibt die Domain `fraesdienst-feind.de`. Geschäftsfelder: **CNC-Fräsen, Lohnfertigung, Bearbeitung diverser Werkstoffe** (Aluminium, Kunststoff, Edelstahl, POM, Messing, Titan), **Prototypen & Kleinserien**, mit regionalem Fokus **Nordrhein-Westfalen / Deutschland**. Vertriebs-/Lead-Quellen sind Website-Kontaktformular, Telefon, Messe, E-Mail und Empfehlung.

Annahmen (branchenüblich, zu bestätigen):

- **Annahme A1:** Es handelt sich um ein KMU mit **weniger als 20 Personen**, die ständig mit der automatisierten Verarbeitung personenbezogener Daten befasst sind. → Daraus folgt: keine gesetzliche Pflicht zur Benennung eines DSB nach § 38 BDSG (siehe Kap. 3).
- **Annahme A2:** Sitz und Datenverarbeitung erfolgen in Deutschland; zuständige Aufsichtsbehörde ist die **LDI NRW** (Landesbeauftragte für Datenschutz und Informationsfreiheit Nordrhein-Westfalen). *(Bundesland vor Erstellung einer Meldung verifizieren.)*
- **Annahme A3:** Es werden **keine besonderen Kategorien** personenbezogener Daten (Art. 9) zu Kunden verarbeitet; im Beschäftigtenkontext fallen begrenzt Gesundheitsdaten an (Krankmeldungen/AU) — Standard bei jedem Arbeitgeber.
- **Annahme A4:** Es findet **kein Profiling und keine automatisierte Einzelentscheidung** i. S. v. Art. 22 statt.

2.2 Rolle der berichtenden Person

David Halko ist **Marketing & Eventmanager**. Datenschutzrelevante Berührungspunkte seiner Rolle:

- Betrieb/Pflege der Website und Marketing-Tools (Analytics, ggf. Newsletter, Social Media),
- Verarbeitung von Interessenten-/Lead-Daten (Kontaktformular, Messekontakte),
- Auswahl und Einbindung externer Dienstleister (Web-Agentur, Tool-Anbieter),
- Erstellung von Marketing-Content, ggf. mit Personenbezug (Kundenreferenzen, Fotos von Events).

David ist **nicht** automatisch Datenschutzbeauftragter; die Marketing-Rolle ist wegen möglicher Interessenkonflikte (Marketing „will“ Daten nutzen) für die DSB-Funktion sogar ungeeignet. Empfohlene Rolle Davids: **Prozessverantwortlicher „Marketing & Website“** innerhalb des Datenschutz-Managements (siehe Rollenmatrix, Kap. 13).

3. Rechtsgrundlagen & Compliance-Check

3.1 Relevante Rechtsgrundlagen

Norm	Bedeutung für Feind GmbH
Art. 6 Abs. 1 DSGVO	Rechtsgrundlagen: lit. b (Vertrag/Anbahnung — Angebote, Aufträge), lit. c (rechtliche Pflicht — Rechnungen/Steuer), lit. f (berechtigtes Interesse — Direktwerbung Bestandskunden, IT-Sicherheit), lit. a (Einwilligung — Analytics, Newsletter).
Art. 7 DSGVO	Bedingungen für Einwilligung (freiwillig, informiert, widerrufbar, Nachweisbarkeit).
Art. 9 DSGVO	Besondere Kategorien — v. a. Gesundheitsdaten von Beschäftigten (AU-Bescheinigungen).
Art. 5, 13, 14 DSGVO	Grundsätze (Zweckbindung, Datenminimierung, Speicherbegrenzung); Informationspflichten.
Art. 15–22 DSGVO	Betroffenenrechte (Auskunft, Berichtigung, Löschung, Einschränkung, Portabilität, Widerspruch).
Art. 28 / 30 / 32 DSGVO	AV-Vertrag, Verzeichnis der Verarbeitungstätigkeiten, Sicherheit der Verarbeitung (TOM).
Art. 33 / 34 / 35 DSGVO	Meldung von Datenpannen (72 h), Benachrichtigung Betroffener, DPIA.
§ 26 BDSG	Beschäftigtendatenschutz.
§ 38 BDSG	Benennungspflicht DSB (ab 20 Personen mit automatisierter Verarbeitung, oder bei DPIA-Pflicht).
§ 25 TDDDG (vormals TTDSG)	Einwilligung für Zugriff auf Endgeräte-Informationen (Cookies, Tracking) — Opt-in-Pflicht.
ePrivacy-Richtlinie	Grundlage der Cookie-/Tracking-Regeln; national umgesetzt im TDDDG.
§ 147 AO, § 257 HGB	Steuer-/handelsrechtliche Aufbewahrungspflichten (siehe Löschkonzept).

3.2 Compliance-Check (Status)

Legende: ● erfüllt · ● teilweise · ● nicht erfüllt / unbekannt

#	Pflicht / Dokument	Rechtsgrundlage	Status	Bemerkung
1	Verzeichnis der Verarbeitungstätigkeiten (VVT)	Art. 30	●	Nicht vorhanden — Vorlage in Anhang A.
2	Datenschutzerklärung Website (aktuell)	Art. 13	●	Vorhanden angenommen, Aktualität unklar — Muster in Anhang E.
3	Impressum	§ 5 DDG	●	Anzunehmen vorhanden; Vollständigkeit prüfen.
4	Cookie-/Consent-Banner mit Opt-in vor GA4	§ 25 TDDDG, Art. 6/7	●	Kritisch — GA4 ist im Einsatz.
5	AV-Verträge mit Auftragsverarbeitern	Art. 28	●	Für Google, Host, Steuerberater, IT-Support, ggf. Lohn.
6	TOM-Dokumentation	Art. 32	●	Nicht dokumentiert — Checkliste in Anhang J.
7	Löschkonzept / Aufbewahrungsfristen	Art. 5 Abs. 1 e	●	Nicht formalisiert — Vorlage in Kap. 4 / Anhang.
8	Prozess Betroffenenrechte	Art. 15–22	●	Nicht dokumentiert — Kap. 10.
9	Datenpannen-Meldeprozess (72 h)	Art. 33/34	●	Nicht dokumentiert — Kap. 9.
10	Prüfung Benennungspflicht DSB	§ 38 BDSG	●	Zu klären (Personenzahl) — s. Annahme A1.
11	Verpflichtung auf Vertraulichkeit (Beschäftigte)	Art. 29, § 53 BDSG	●	Vorlage empfohlen.
12	DPIA (falls erforderlich)	Art. 35	● / ●	Nach aktueller Einschätzung nicht zwingend (Kap. 8).
13	Mitarbeiterschulung Datenschutz	Art. 39 (Best Practice)	●	Kein Nachweis — Kap. 13.
14	US-Transfer-Nachweis (DPF/SCC)	Art. 44 ff.	●	Google DPF-zertifiziert; dokumentieren.

Kernaussage: Die technische Datenverarbeitung ist überschaubar und beherrschbar. Der Handlungsbedarf liegt fast vollständig in **Dokumentation, Consent-Konfiguration und Prozessen** — nicht in teurer Technik.

4. Dateninventar & Verzeichnis der Verarbeitungstätigkeiten (VVT)

4.1 Kategorien personenbezogener Daten

Betroffenengruppe	Typische Datenkategorien
Kunden / Ansprechpartner	Name, Firma, Funktion, Anschrift, E-Mail, Telefon, Auftragsdaten, Rechnungs-/Zahlungsdaten, techn. Zeichnungen/CAD (i. d. R. kein Personenbezug, aber vertraulich).
Interessenten / Leads	Name, Firma, E-Mail, Telefon, Anfrageinhalt (Kontaktformular/Messe).
Lieferanten / Dienstleister	Ansprechpartner, Kontakt-, Vertrags- und Zahlungsdaten.
Beschäftigte	Stammdaten, Vertrag, Lohn-/Sozialversicherungsdaten, Bankverbindung, Arbeitszeit, Gesundheitsdaten (AU) — Art. 9.
Bewerber	Bewerbungsunterlagen, Lebenslauf, Zeugnisse, Kontaktdaten.
Website-Besucher	IP-Adresse, Geräte-/Browserdaten, Nutzungsdaten (Analytics), Cookie-IDs.

4.2 Verzeichnis der Verarbeitungstätigkeiten (ausgefüllte Beispiel-Einträge)

Vollständige, kopierfähige Tabellen-/CSV-Vorlage siehe **Anhang A**. Auszug:

Verarbeitung	Zweck	Rechtsgrundlage	Datenkategorien	Speicherort	Aufbewahrung	Zugriff	Empfänger/Dritte
Kundenverwaltung / Auftragsabwicklung	Angebot, Vertrag, Fertigung, Rechnung	Art. 6 I b, c	Stamm-, Auftrags-, Rechnungsdaten	ERP/Ablage, Buchhaltung, Cloud-Speicher	Rechnungen 8–10 J. (§ 147 AO); sonst 3 J. nach Vertragsende (§ 195 BGB)	GF, Vertrieb, Buchhaltung, Fertigung	Steuerberater, Versand, Zahlungsdienstl.
Interessenten/Kontaktformular	Bearbeitung von Anfragen	Art. 6 I b (Anbahnung), f	Name, Firma, Kontakt, Anliegen	Website – E-Mail/CRM(CSV)	Löschung nach Erledigung, spät. 6–12 Mon. wenn kein Vertrag	Vertrieb, Marketing	Hoster, Formular-Dienst
Website-Analyse (GA4)	Reichweiten-/Nutzungsanalyse	Art. 6 I a (Einwilligung)	IP, Geräte-/Nutzungsdaten, Cookie-IDs	Google (EU/USA)	GA4-Standard, konfigurierbar (z. B. 2–14 Mon.)	Marketing	Google (Auftragsverarb., DPF)
Suchperformance (Search Console)	SEO-Analyse	Art. 6 I f	Aggregierte Suchdaten (i. d. R. kein Personenbezug)	Google	Google-seitig	Marketing	Google
Beschäftigtenverwaltung/Lohn	Personalverwaltung, Lohn	Art. 6 I b, c; § 26 BDSG; Art. 9 II b	Stamm-, Lohn-, Gesundheitsdaten	Personalakte, Lohnsystem	6–10 J. lohnsteuer-/sozialrechtlich; danach Löschung	GF, Personal, Lohnbüro	Steuerberater/Lohn Finanzamt, SV-Träger, Berufsgenossensch
Bewerbermanagement	Auswahlverfahren	Art. 6 I b; § 26 BDSG	Bewerbungsdaten	E-Mail/Ablage	Absage: Löschung nach 6 Monaten; Einwilligung für Talentpool	GF, Personal	—
Newsletter/Marketing (falls genutzt)	Direktwerbung	Art. 6 I a	E-Mail, Name, ggf. Interessen	Newsletter-Tool	Bis Widerruf; Consent-Log dauerhaft	Marketing	Newsletter-Anbieter (AVV!)
IT-Sicherheit/Server-Logs	Betriebssicherheit, Fehleranalyse	Art. 6 I f	IP, Zeitstempel, Zugriffsdaten	Hoster/Server	i. d. R. 7–30 Tage	IT/Hoster	Hoster (AVV)

5. Datenflussanalyse (Data Flow Mapping)

5.1 Ein- und Ausgangspunkte

Eingang (Erfassung): Website-Kontaktformular · E-Mail · Telefon · Messe/persönlich · Papierdokumente (Zeichnungen, Lieferscheine) · Bewerbungen · Maschinen-/Fertigungsdaten (CAD, Fertigungsaufträge — i. d. R. Sach-, kein Personenbezug).

Ausgang (Weitergabe): Steuerberater/Lohnbüro · Finanzamt/SV-Träger (gesetzlich) · Versand-/Logistikdienstleister · Zahlungsdienstleister/Bank · Google (Analytics/Search Console) · Hosting-Provider · IT-Support/Fernwartung · ggf. Newsletter-/Marketing-Tools · GitHub (nur Code/Konfiguration, **keine** produktiven CRM-Rohdaten — durch `.gitignore` ausgeschlossen).

5.2 Lebenszyklus-Tabelle (Erfassung → Löschung)

Datenfluss	1. Erfassung	2. Speicherung	3. Verarbeitung	4. Weitergabe	5. Löschung	Drittland?
Kundenauftrag	Formular/E-Mail/Tel.	ERP/Ablage/Cloud	Angebot → Fertigung → Rechnung	Steuerberater, Versand	Fristablauf (8–10 J.)	Cloud-Standort prüfen
Website-Analyse	Browser (Cookie)	Google GA4	Aggregation, Reporting	Google	GA4-Retention	Ja — USA (DPF)
Lead/Interessant	Formular/Messe	E-Mail/CRM-CSV	Nachfassen, Angebot	intern	nach Erledigung	Hoster-Standort prüfen
Beschäftigte/Lohn	Personalbogen	Personalakte/Lohnsystem	Abrechnung	Lohnbüro, FA, SV	Fristablauf	i. d. R. EU
Bewerbung	E-Mail	Ablage	Auswahl	intern	6 Mon. n. Absage	i. d. R. EU
Server-Logs	HTTP-Request	Hoster	Fehler-/Sicherheitsanalyse	Hoster	7–30 Tage	Hoster-Standort prüfen

5.3 Grenzüberschreitende Übermittlungen (Drittstaaten)

- Google (GA4, Search Console, Google Cloud):** Übermittlung in die **USA** möglich. Rechtsgrundlage: **EU-US Data Privacy Framework** (Angemessenheitsbeschluss der EU-Kommission vom 10.07.2023); Google LLC ist DPF-zertifiziert. Ergänzend Standardvertragsklauseln (SCC) als Auffanglösung. → **Dokumentieren**.
- GitHub (Microsoft):** Übermittlung **USA** möglich; enthält nur Code/Konfiguration, **keine** produktiven personenbezogenen Rohdaten (durch `.gitignore` sichergestellt).
- Hosting/E-Mail/Newsletter:** Standort und Drittstaatenbezug **zu verifizieren** (offene Frage F-04).

6. Technische und organisatorische Maßnahmen (TOM)

Empfohlene TOM nach Art. 32 DSGVO, mit Priorität (H/M/N) und grobem Aufwand.

Bereich	Maßnahme	Prio	Aufwand
Zugriffskontrolle	Rollen-/Berechtigungskonzept „need-to-know“; individuelle Logins (keine Sammelkonten)	H	mittel
Authentifizierung	Passwort-Policy (min. 12 Zeichen, Passwortmanager) + MFA für E-Mail, Cloud, Google, GitHub, Buchhaltung	H	gering–mittel
Verschlüsselung (Transit)	TLS/HTTPS für Website & E-Mail (TLS-Versand), HSTS	H	gering
Verschlüsselung (at rest)	Geräteverschlüsselung (BitLocker/FileVault) für Laptops/mobile Geräte; verschlüsselte Backups	H	gering
Backup	3-2-1-Strategie, regelmäßige Wiederherstellungstests, definierte Aufbewahrung	H	mittel
Patch-Management	Automatische Updates OS/CMS/Plugins/AV; Update-Turnus dokumentieren	H	gering
Endpoint-Security	Aktueller Virenschutz/EDR, Firewall, Bildschirmsperre	M	gering
Logging/Monitoring	Zugriffs-/Server-Logs mit definierter Aufbewahrung (7–30 Tage); Auswertung nur zweckgebunden	M	gering
Physische Sicherheit	Abschließbare Serverräume/Aktenschränke, Zutrittsregelung, Aktenvernichtung (DIN 66399)	M	gering–mittel
Mobile Geräte	MDM/Trennung privat/dienstlich, Fernlöschung bei Verlust	M	mittel
Fernwartung	Nur nach Bedarf/Freigabe, protokolliert, verschlüsselt; AVV mit IT-Dienstleister	M	gering
Löschung/Entsorgung	Automatisierte Löschroutinen; sichere Datenträgervernichtung	M	mittel
Belastbarkeit	Notfallplan (IT-Ausfall/Ransomware), Wiederanlaufkonzept	M	mittel

7. Drittanbieter, Auftragsverarbeitung & Verträge

7.1 Vermutete Auftragsverarbeiter (Art. 28) — zu verifizieren

Dienstleister	Zweck	AVV erforderlich?	Drittland	Status
Google (LLC/Ireland)	GA4, Search Console, Google Cloud	Ja	USA (DPF)	AVV via Google-Bedingungen aktivieren/prüfen
Hosting-/E-Mail-Provider	Website, Postfächer, Logs	Ja	prüfen	AVV einholen
Steuerberater	Buchhaltung, Jahresabschluss	i. d. R. eigenständig Verantwortlicher (Berufsträger), kein AVV	EU	schriftliche Klärung
Lohnabrechnung	Gehaltsabrechnung	AVV oder Berufsträger-Regelung	EU	klären
IT-Support / Fernwartung	Wartung, Support	Ja	prüfen	AVV einholen
Newsletter-Tool (<i>falls genutzt</i>)	E-Mail-Marketing	Ja	prüfen	AVV einholen
Versand-/Logistik	Warenversand	meist eigenständig Verantwortlicher	EU	klären
GitHub (Microsoft)	Code-/Config-Hosting	Ja (soweit personenbezogen)	USA (DPF)	prüfen; keine Rohdaten

7.2 AVV-Prüfliste

1. Vertrag schriftlich/elektronisch vorhanden und aktuell (DSGVO-konform, Art. 28 Abs. 3).
2. Gegenstand, Dauer, Art, Zweck, Datenkategorien, Betroffene benannt.
3. Weisungsbindung, Vertraulichkeit, TOM (Art. 32) geregelt.
4. Unterauftragsverarbeiter (Subunternehmer) mit Genehmigungsvorbehalt/Liste.
5. Unterstützungspflichten bei Betroffenenrechten und Datenpannen.
6. Löschung/Rückgabe nach Vertragsende.
7. **Kontroll-/Audit-Rechte** und Nachweispflichten.
8. Drittlandtransfer-Grundlage (DPF/SCC) dokumentiert.

Muster-AVV-Klauseln siehe **Anhang C**.

8. Datenschutz-Folgenabschätzung (DPIA)

8.1 Wann ist eine DPIA erforderlich? (Art. 35)

Pflicht bei „voraussichtlich hohem Risiko“, insbesondere bei: systematischer umfangreicher Überwachung, umfangreicher Verarbeitung besonderer Kategorien, systematischer Bewertung/Scoring (Profiling) — sowie bei Verarbeitungen auf der **Muss-Liste der Aufsichtsbehörden**.

Einschätzung Feind GmbH: Nach aktuellem Kenntnisstand ist **keine DPIA zwingend** — es erfolgt kein großflächiges Tracking-/Scoring, keine umfangreiche Verarbeitung besonderer Kategorien. Website-Analyse mit GA4 wird als **Standardrisiko** bewertet, sofern Consent und IP-Kürzung greifen. → **Kurz-Schwellwertprüfung dokumentieren** (Nachweis, dass geprüft und verneint wurde).

8.2 Vorgehen

1. Beschreibung der Verarbeitung & Zwecke → 2. Notwendigkeits-/Verhältnismäßigkeitsprüfung →
2. Risikoidentifikation (Betroffenensicht) → 4. Bewertung (Eintritt × Schwere) →

3. Abhilfemaßnahmen → 6. Restrisiko & Freigabe → 7. Monitoring/Review.

Vollständige **DPIA-Vorlage mit ausgefüllten Beispielen** (Kundenverwaltung, CAD-Dateien, Fernwartung) siehe **Anhang B**.

9. Datensicherheit & Vorfallmanagement

9.1 Incident-Response-Verfahren

1. **Erkennung & Meldung intern:** Jede(r) Beschäftigte meldet Verdacht sofort an GF/IT-Verantwortlichen (Meldeweg dokumentieren).
2. **Sofortmaßnahmen & forensische Sicherung:** System isolieren, Beweise/Logs sichern, nichts vorschnell löschen, Umfang eingrenzen.
3. **Bewertung (Risiko für Betroffene):** Art, Umfang, Sensibilität, Anzahl Betroffener, mögliche Folgen.
4. **Meldung an Aufsichtsbehörde (Art. 33):** bei Risiko **innerhalb von 72 Stunden** nach Bekanntwerden (LDI NRW). Verzögerungen begründen.
5. **Benachrichtigung Betroffener (Art. 34):** bei **hohem** Risiko unverzüglich, in klarer Sprache.
6. **Dokumentation:** Jeder Vorfall wird im **Datenpannen-Register** erfasst (auch nicht meldepflichtige) — Nachweispflicht Art. 33 Abs. 5.
7. **Nachbereitung:** Ursachenanalyse, TOM anpassen, ggf. Schulung.

Muster-Meldung an Aufsichtsbehörde und Betroffenen-Benachrichtigung siehe **Anhang F**; **Incident-Report-Formular** siehe **Anhang G**.

10. Betroffenenrechte & Prozesse

10.1 Rechte und Fristen

Recht	Norm	Frist
Auskunft	Art. 15	1 Monat (verlängerbar um 2 Monate)
Berichtigung	Art. 16	unverzüglich, i. d. R. 1 Monat
Löschung („Recht auf Vergessenwerden“)	Art. 17	1 Monat (Aufbewahrungspflichten beachten)
Einschränkung	Art. 18	1 Monat
Datenübertragbarkeit	Art. 20	1 Monat
Widerspruch (u. a. Direktwerbung)	Art. 21	unverzüglich

10.2 Prozess

1. Eingang zentral erfassen (Datum!) → 2. **Identität prüfen** (verhältnismäßig, keine übermäßigen Daten) → 3. Betroffene(n) und Daten ermitteln → 4. Antwort erstellen (ggf. mit DSB abstimmen) → 5. fristgerecht **kostenfrei** antworten → 6. dokumentieren.

Muster-Antwortschreiben (Auskunft, Löschung) siehe **Anhang H**.

11. Einwilligungen, Informationspflichten & Datenschutzerklärung

- **Website-Datenschutzerklärung (Art. 13):** vollständig, aktuell, leicht auffindbar. Muster in **Anhang E**.
- **Cookie-/Consent-Banner: Opt-in vor** dem Laden nicht notwendiger Technologien (GA4!), granular (Ablehnen so einfach wie Akzeptieren), Widerruf jederzeit. Muster-Consent-Texte in **Anhang D**.
- **Newsletter/Marketing: Double-Opt-in**, klarer Zweck, Widerrufshinweis in jeder Mail.
- **Consent-Logs:** Nachweis der Einwilligung protokollieren (Zeitpunkt, eingewilligte Zwecke, Version des Textes, technischer Nachweis) — Aufbewahrung bis zur Verjährung möglicher Ansprüche.

12. Spezifische Prüfung Web/Online-Tools

Wichtig: Ein Live-Abruf der Website war in dieser Arbeitsumgebung technisch gesperrt. Die folgenden Punkte sind **verifiziert (V)** aus der internen Codebasis oder als **Annahme (A)** markiert und mit **hoher Priorität** durch ein Live-Website-Audit zu verifizieren (offene Frage F-01).

(V) Verifiziert: Google Analytics 4 ist im Einsatz (Property mit Key-Event anfrage_gesendet); die Domain ist als Google-Search-Console-Property registriert; ein Website-Kontaktformular existiert (Lead-Quelle „Website-Formular“).

Prüf-Checkliste (Soll-Zustand):

1. **Tracking (GA4):** lädt **erst nach Opt-in**? IP-Anonymisierung/Datenaufbewahrung konfiguriert? Google-Signals deaktiviert, sofern keine Einwilligung? **(A)**
2. **Google Tag Manager:** vorhanden? Tags nur nach Consent auslösend? **(A)**
3. **Google Fonts: lokal gehostet** (nicht dynamisch von Google-Servern nachladen — vgl. LG München 2022)? **(A — häufiges KMU-Risiko)**
4. **Google Maps / reCAPTCHA / YouTube:** nur nach Consent (2-Klick-Lösung)? **(A)**
5. **Social-Media-Plugins:** kein direktes Einbetten ohne Consent? **(A)**
6. **CDN / externe Skripte:** Herkunft/Drittlandbezug dokumentiert? **(A)**
7. **SSL/TLS:** HTTPS erzwungen, gültiges Zertifikat, **HSTS**? **(A)**
8. **CSP (Content-Security-Policy):** gesetzt (Härtung gegen Skript-Injection)? **(A)**
9. **Cookies/LocalStorage:** Inventar aller gesetzten Cookies (Name, Zweck, Laufzeit, Anbieter)? **(A)**
10. **Consent-Banner-Tool:** vorhanden (z. B. Cookiebot, Usercentrics, Borlabs, Complianz)? Opt-in, granular, Widerruf, Consent-Log? **(A)**

Empfehlungen: Consent-Management-Plattform einführen und GA4 sauber daran koppeln; Google Fonts lokal einbinden; alle Cookies inventarisieren; Datenschutzerklärung an die tatsächlich geladenen Dienste anpassen; TLS/HSTS erzwingen.

13. Mitarbeiter, Schulung & Rollen

13.1 Schulung

- **Inhalte:** DSGVO-Grundlagen, sicheres E-Mail-/Passwortverhalten, Phishing, Umgang mit Kunden-/Beschäftigtendaten, Meldung von Datenpannen, Clean-Desk.
- **Frequenz:** Basisschulung bei Eintritt + **jährliche** Auffrischung; anlassbezogen bei Änderungen.
- **Nachweis:** Teilnahmeliste/Signatur, Schulungsdatum, Inhalt (Nachweispflicht).

13.2 Rollenmatrix

Rolle	Zuständigkeit	Vorschlag
Verantwortlicher	Gesamtverantwortung DSGVO	Geschäftsführung
DSB (falls nötig/gewünscht)	Beratung, Überwachung, Kontakt Behörde	extern empfohlen (Unabhängigkeit)
IT-Admin/-Verantwortlicher	TOM, Backup, Zugriffe, Patches	intern/IT-Dienstleister
Prozessverantw. Marketing/Website	Website, Analytics, Consent, Newsletter	David Halko
Prozessverantw. Personal	Beschäftigten-/Bewerberdaten	Personal/GF
Prozessverantw. Buchhaltung	Rechnungs-/Zahlungsdaten	Buchhaltung

14. Risikoanalyse & Priorisierung

Bewertung: Eintrittswahrscheinlichkeit (1–3) × Auswirkung (1–3) = Score (1–9).

#	Risiko	W	A	Score	Prio
R1	GA4/Tracking ohne rechtssicheres Consent	3	3	9	Hoch
R2	Fehlende AV-Verträge (Art. 28)	3	2	6	Hoch
R3	Fehlendes VVT (Art. 30)	3	2	6	Hoch
R4	Veraltete/unvollständige Datenschutzerklärung	3	2	6	Hoch
R5	US-Transfer nicht dokumentiert	2	2	4	Mittel
R6	Kein Löschkonzept	2	2	4	Mittel
R7	Kein Datenpannen-Prozess (72 h)	2	3	6	Hoch
R8	Fehlende TOM-Dokumentation	2	2	4	Mittel
R9	Google Fonts extern eingebunden	2	1	2	Niedrig
R10	Keine Mitarbeiterschulung	2	2	4	Mittel
R11	Kein MFA auf kritischen Konten	2	3	6	Hoch
R12	Bewerber-/Beschäftigtendaten ohne Löschfristen	2	2	4	Mittel

Zeitliche Zuordnung:

- **Kurzfristig (0–3 Mon.):** R1, R4, R7, R11, R2/R3 (Start).
- **Mittelfristig (3–12 Mon.):** R2/R3 (Abschluss), R5, R6, R8, R10, R12.
- **Langfristig (>12 Mon.):** R9, kontinuierliche Verbesserung, Audits.

15. Audit- & Monitoringplan

- **Interne Kurz-Audits:** halbjährlich (Checkliste Anhang J/L).
- **Jährlicher Datenschutz-Review:** VVT, AVV, Löschungen, Schulungen, Vorfälle.
- **KPIs:** % abgeschlossene AVV, Anzahl offener Betroffenenanfragen/Fristtreue, Zeit bis Datenpannen-Meldung, Schulungsquote, Anzahl offener Hoch-Risiken.
- **Reporting an GF:** halbjährlich (1-Seiter mit Ampelstatus).

16. Antworten auf den Fragen-Katalog

Meta-Fragen zum Bericht (aus dem Auftrag):

- *Thema:* DSGVO-Status und Maßnahmenplan für fraesdienst-feind.de. *Blickwinkel:* interne Bestandsaufnahme + Handlungsplan. *Zielgruppe:* GF/DSB/IT/Behörde. *Umfang:* ausführlich (dieser Bericht). *Format:* gegliederter Bericht + Vorlagen. *Ton:* sachlich, praxisnah. *Deadline:* siehe Check-in unten. *Quellen:* interne Codebasis + geltendes Recht (DSGVO/BDSG/TDDDG) + Branchenpraxis.

Fach-Fragen:

Frage	Antwort (V = verifiziert, A = Annahme)
Interne Systeme/Tools	V: Google Search Console, GA4, Google Cloud (Service-Account), GitHub/Actions, SMTP-Versand (optional), Website-Kontaktformular, CRM als CSV/XLSX. A: Buchhaltungssoftware, Cloud-Speicher (OneDrive/Google Drive), ERP, Backup-Lösung — zu benennen (F-02).
Externe Dienstleister mit Datenzugriff	A: Hoster, Steuerberater, ggf. Lohnbüro, IT-Support, Google, ggf. Newsletter-Anbieter (F-03).
Unterschiedene AVVs vorhanden?	A: unbekannt — vermutlich unvollständig (F-05, Prio hoch).
Drittstaaten-transfer?	V/A: ja, via Google (USA, DPF); weitere prüfen (F-04).
Datenkategorien	siehe Kap. 4.1 (Kunden, Interessenten, Lieferanten, Beschäftigte, Bewerber, Website-Besucher).
Besondere Kategorien (Art. 9)?	A: nur Beschäftigten-Gesundheitsdaten (AU); keine bei Kunden.
Aufbewahrung/Löschkonzept?	A: nicht formalisiert — Vorlage Kap. 4 / Löschkonzept nötig (F-07).
Backups?	A: vorhanden, Details/Fristen unklar (F-08).
Zugriffskontrolle/MFA?	A: MFA vermutlich nicht flächendeckend (R11, F-09).
Patch-Management?	A: unklar — dokumentieren (F-10).
Datenpannen-Protokoll/-Vorfall?	A: kein Protokoll bekannt; kein gemeldeter Vorfall (F-11).
Einwilligungen dokumentiert?	A: Consent-Log für GA4/Newsletter fraglich (R1).
Betroffenenrechte-Prozess?	A: nicht dokumentiert (Kap. 10).
Schulungen?	A: keine dokumentiert (R10).
Logs & Aufbewahrung?	A: Server-Logs beim Hoster, Dauer unklar (F-06).
Verschlüsselung?	A: HTTPS aktiv angenommen; Geräte-/Backup-Verschlüsselung prüfen.
Physische Sicherheit?	A: zu prüfen (Serverraum/Aktenschranke).
Tracking/Social-Plugins?	V: GA4; weitere A (F-01).
Schnittstellen/APIs/Zapier/Webhooks?	V: Google-APIs (GSC/GA4), GitHub Actions, SMTP. A: kein Zapier/IFTTT bekannt.
Automatisierte Entscheidung/Profiling?	A: nein (Annahme A4).
Löschkonzept bei Kundenende?	A: nicht vorhanden (F-07).
Fehlende Nachweise?	VVT, AVV, TOM, Löschkonzept, Consent-Log, Schulungsnachweise (Kap. 3.2).
Prioritäten kurz/mittel/lang?	siehe Kap. 14 & Roadmap (Anhang N).

17. Offene Fragen (priorisiert)

Priorität HOCH (zur Beantwortung binnen 2–4 Wochen):

- **F-01:** Live-Website-Audit — welche Cookies/Tracker/Fonts/Consent-Tool sind real aktiv?
(Benötigt: Zugriff auf Website/CMS oder externes Scan-Ergebnis.)
- **F-05:** Welche AV-Verträge existieren bereits, sind sie aktuell/vollständig?
(Benötigt: Vertragsübersicht.)
- **F-09:** Ist MFA auf E-Mail, Cloud, Google, GitHub, Buchhaltung aktiv?
- **F-11:** Existiert ein Datenpannen-Meldeprozess/-Register?

Priorität MITTEL (4–8 Wochen):

- **F-02:** Welche Buchhaltungs-/ERP-/Cloud-Speicher-/Backup-Lösungen sind im Einsatz (Anbieter, Standort)?
- **F-03:** Vollständige Liste externer Dienstleister mit Datenzugriff.
- **F-04:** Serverstandorte Hosting/E-Mail/Newsletter (Drittstaatenbezug?).
- **F-07:** Existiert ein Löschkonzept mit Fristen?
- **F-12:** Personenzahl mit automatisierter Verarbeitung → DSB-Pflicht (§ 38 BDSG)?

Priorität NIEDRIG (laufend):

- **F-06:** Log-Aufbewahrungsdauer beim Hoster.

- **F-08:** Backup-Fristen und Wiederherstellungstests.
- **F-10:** Patch-/Update-Turnus dokumentiert?

18. Anhänge & Vorlagen

- **Anhang A** — Verzeichnis der Verarbeitungstätigkeiten (Tabelle + CSV-als-Text)
- **Anhang B** — DPIA-Formular (mit Beispielen)
- **Anhang C** — Muster-AVV-Klauseln
- **Anhang D** — Muster-Einwilligungstexte (Newsletter, Consent-Banner)
- **Anhang E** — Muster-Datenschutzzerklärung (Website)
- **Anhang F** — Muster-Meldung Datenschutzverletzung (Behörde + Betroffene)
- **Anhang G** — Incident-Report-Formular
- **Anhang H** — Muster-Antwortschreiben Betroffenenrechte
- **Anhang I** — Checkliste Drittanbieter/AVV
- **Anhang J** — Checkliste IT-Security/TOM
- **Anhang K** — To-Do-Plan mit Verantwortlichkeiten
- **Anhang L** — Checkliste Website-Datenschutz
- **Anhang M** — Annahmenverzeichnis
- **Anhang N** — 12-Monats-Roadmap
- **Anhang O** — Risiko-Dashboard
- **Anhang P** — Top-5-Sofortmaßnahmen (1-Seiter GF)
- **Anhang Q** — Anleitung „Bericht aktualisieren“

Anhang A — Verzeichnis der Verarbeitungstätigkeiten (VVT)

CSV-Vorlage (kopierfähig; Trennzeichen ;) :

```
Nr;Verarbeitungstaetigkeit;Zweck;Rechtsgrundlage;Betroffenengruppe;Datenkategorien;Empfaenger;Drittland;Loeschfrist;TOM;Verantwortl
ich
1;Kundenverwaltung/Auftragsabwicklung;Vertragserfuellung;Art.6 I
b/c;Kunden;Stamm-, Auftrags-, Rechnungsdaten;Steuerberater,Versand;Cloud pruefen;8-10 J. (AO/HGB) bzw. 3 J.
(BGB);Rollenrechte,Backup,Verschluesselung;GF/Vertrieb
2;Kontaktformular/Interessenten;Anfragebearbeitung;Art.6 I b/f;Interessenten;Name,Firma,Kontakt,Anliegen;-;Hoster;nach Erledigung,
max 6-12 Mon.;TLS,Zugriffsschutz;Marketing
3;Website-Analyse GA4;Reichweitenanalyse;Art.6 I a (Einwilligung);Website-Besucher;IP,Geraete-/Nutzungsdaten,Cookie-IDs;Google;USA
(DPF);GA4-Retention (konfigurierbar);Consent,IP-Kuerzung;Marketing
4;Suchperformance Search Console;SEO;Art.6 I f;Website-Besucher;aggregierte Suchdaten;Google;USA (DPF);Google-seitig;Service-
Account;Marketing
5;Beschaeftigtenverwaltung/Lohn;Personal/Lohn;Art.6 I b/c,§26 BDSG,Art.9 II
b;Beschaeftigte;Stamm-, Lohn-, Gesundheitsdaten;Lohnbuero,FA,SV;EU;6-10 J.
steuer-/sozialrechtl.;Zugriffsbeschr.,Verschluesselung;GF/Personal
6;Bewerbermanagement;Auswahlverfahren;Art.6 I b,§26 BDSG;Bewerber;Bewerbungsdaten;-;EU;6 Mon. nach
Absage;Zugriffsschutz,Loeschung;GF/Personal
7;Newsletter/Marketing;Direktwerbung;Art.6 I a;Interessenten/Kunden;E-Mail,Name;Newsletter-Anbieter;pruefen;bis Widerruf; Consent
dauerhaft;Double-Opt-in,Consent-Log;Marketing
8;Lieferantenverwaltung;Beschaffung;Art.6 I b/f;Lieferanten;Kontakt-,Vertrags-,Zahlungsdaten;Bank;EU;3 J. nach
Vertragsende;Zugriffsschutz;Einkauf/Buchhaltung
9;IT-Sicherheit/Server-Logs;Betriebssicherheit;Art.6 I f;Website-Besucher;IP,Zeitstempel;Hoster;pruefen;7-30
Tage;Zugriffsschutz,Loeschautomatik;IT
```

Anhang B — DPIA-Formular (mit Beispielen)

```
DATENSCHUTZ-FOLGENABSCHAETZUNG (Art. 35 DSGVO)
1. Verarbeitung: .....
2. Verantwortlicher / DSB: .....
3. Zweck(e): .....
4. Datenkategorien / Betroffene: .....
5. Notwendigkeit & Verhaeltnismaessigkeit: .....
6. Risiken fuer Betroffene:
  - Vertraulichkeit (unbefugter Zugriff): .....
  - Integritaet (Veraenderung): .....
  - Verfuegbarkeit (Verlust): .....
7. Bewertung: Eintritt (1-3) x Schwere (1-3) = Score:
8. Abhilfemassnahmen (TOM): .....
9. Restrisiko: [ ] akzeptabel [ ] nicht akzeptabel
10. Freigabe (GF/DSB), Datum: .....
11. Naechster Review: .....

BEISPIEL 1 - Kundenverwaltung: Risiko mittel; Score 4; Massnahmen: Rollenrechte, MFA,
Backup, Verschluesselung; Restrisiko akzeptabel.
BEISPIEL 2 - CAD-/Fertigungsdaten (Kunden-Know-how): i.d.R. kein Personenbezug, aber hohe
Vertraulichkeit; Massnahmen: strenge Zugriffskontrolle, Verschluesselung, NDA; Restrisiko
akzeptabel bei Umsetzung.
BEISPIEL 3 - Fernwartung: Risiko mittel-hoch (externer Zugriff); Massnahmen: AVV, Zugriff nur
nach Freigabe, Protokollierung, Verschluesselung; Restrisiko akzeptabel.
```

Anhang C — Muster-AVV-Klauseln

Textbaustein — vor Verwendung rechtlich prüfen lassen (Rechtsabteilung/Fachanwalt).

§1 Gegenstand & Weisungsbindung

Der Auftragnehmer verarbeitet personenbezogene Daten ausschliesslich im Auftrag und nach dokumentierter Weisung des Auftraggebers (Art. 28 Abs. 3 lit. a DSGVO).

§2 Vertraulichkeit

Der Auftragnehmer setzt nur zur Vertraulichkeit verpflichtete Personen ein (Art. 28 Abs. 3 lit. b, Art. 29, 32 Abs. 4).

§3 Technisch-organisatorische Massnahmen

Der Auftragnehmer gewährleistet die Sicherheit der Verarbeitung nach Art. 32 (siehe Anlage TOM).

§4 Unterauftragsverarbeiter

Der Einsatz von Subunternehmern bedarf der vorherigen Genehmigung; eine aktuelle Liste ist beigelegt; Weiterreichung der Pflichten wird sichergestellt.

§5 Unterstützungsspflichten

Der Auftragnehmer unterstützt bei Betroffenenrechten (Art. 12-23) und Datenpannen (Art. 33/34) sowie bei DPIA (Art. 35).

§6 Löschung/Rückgabe

Nach Beendigung werden Daten nach Wahl des Auftraggebers gelöscht oder zurückgegeben, sofern keine Aufbewahrungspflicht besteht.

§7 Nachweise & Kontrolle

Der Auftragnehmer weist die Einhaltung nach und ermöglicht Audits/Inspektionen (Art. 28 Abs. 3 lit. h).

§8 Drittlandtransfer

Übermittlungen in Drittländer erfolgen nur auf zureichender Grundlage (Angemessenheitsbeschluss/DPF bzw. Standardvertragsklauseln, Art. 44 ff.).

Anhang D — Muster-Einwilligungstexte

Textbausteine — rechtlich prüfen lassen.

Newsletter (Double-Opt-in):

[] Ja, ich möchte den Newsletter der Fräsdienst-Service E. Feind GmbH mit Informationen zu Produkten, Leistungen und Angeboten per E-Mail erhalten. Die Einwilligung kann ich jederzeit mit Wirkung für die Zukunft widerrufen (Abmelde-link in jeder E-Mail oder E-Mail an [Kontakt]).
Hinweise zur Verarbeitung: siehe Datenschutzerklärung.

Consent-Banner (Kurztext):

Wir verwenden Cookies und ähnliche Technologien. Notwendige sind für den Betrieb der Website erforderlich. Für Statistik/Analyse (z. B. Google Analytics 4) setzen wir Cookies nur mit Ihrer Einwilligung. Sie können frei entscheiden und Ihre Auswahl jederzeit unter "Einstellungen" widerrufen.
[Alle akzeptieren] [Nur notwendige] [Einstellungen]

Einwilligung Foto/Referenz (Marketing/Event):

Ich willige ein, dass die von mir am [Datum/Anlass] angefertigten Fotos/Videos zu Marketingzwecken (Website, Social Media, Print) verwendet werden dürfen. Die Einwilligung ist freiwillig und jederzeit für die Zukunft widerrufbar (Kontakt: [E-Mail]).

Anhang E — Muster-Datenschutzerklärung (Website, Grundgerüst)

Grundgerüst — auf tatsächlich eingesetzte Dienste anpassen; rechtlich prüfen lassen.

1. Verantwortlicher
Fräsdienst-Service E. Feind GmbH, [Anschrift], [E-Mail], [Telefon]. [DSB, falls vorhanden]

2. Allgemeines / Ihre Rechte
Auskunft, Berichtigung, Löschung, Einschränkung, Datenübertragbarkeit, Widerspruch;
Beschwerderecht bei der Aufsichtsbehörde (LDI NRW).

3. Server-Logfiles (Art. 6 I f)
Beim Aufruf werden IP-Adresse, Datum/Uhrzeit, abgerufene Datei etc. verarbeitet; Speicherung
[X Tage] zur Betriebssicherheit.

4. Kontaktformular / E-Mail (Art. 6 I b/f)
Verarbeitung der Angaben zur Bearbeitung der Anfrage; Löschung nach Erledigung, sofern keine
Aufbewahrungspflicht.

5. Cookies & Einwilligung (§ 25 TDDDG, Art. 6 I a)
Nicht notwendige Cookies/Technologien nur mit Einwilligung; Widerruf jederzeit.

6. Google Analytics 4 (Art. 6 I a)
Nur nach Einwilligung; Anbieter Google Ireland/LLC; Übermittlung in die USA möglich
(EU-US Data Privacy Framework); IP-Kürzung aktiviert; Speicherdauer [X].

7. Weitere Dienste [Google Fonts lokal / Maps / reCAPTCHA / Newsletter etc.]
[nur auführen, was tatsächlich eingesetzt wird]

8. Empfänger / Auftragsverarbeiter
Hosting, IT-Dienstleister, ggf. Newsletter-Anbieter (jeweils mit AVV).

9. Drittlandtransfer
Grundlage DPF/SCC (Art. 44 ff.).

10. Stand: [Datum]

Anhang F — Muster-Meldung Datenschutzverletzung

An die Aufsichtsbehörde (Art. 33):

Meldung einer Verletzung des Schutzes personenbezogener Daten (Art. 33 DSGVO)
Verantwortlicher: Fräsdienst-Service E. Feind GmbH, [Anschrift, Kontakt]
Ansprechpartner: [Name, Funktion, Kontakt]
1. Zeitpunkt/Zeitraum des Vorfalls und der Kenntnisnahme: ...
2. Art der Verletzung (Vertraulichkeit/Integrität/Verfügbarkeit): ...
3. Betroffene Datenkategorien und ungefähre Anzahl Betroffener/Datensätze: ...
4. Wahrscheinliche Folgen: ...
5. Ergriffene/vorgeschlagene Massnahmen: ...
6. Wurde >72h überschritten? Begründung: ...
Ort, Datum, Unterschrift

An Betroffene (Art. 34):

Information über eine Verletzung des Schutzes Ihrer personenbezogenen Daten
Sehr geehrte/r ...,
am [Datum] ist es zu [kurze, klare Beschreibung] gekommen. Betroffen sind folgende Daten: ...
Mögliche Folgen: ... Wir haben folgende Massnahmen ergriffen: ...
Empfehlung an Sie: [z. B. Passwort ändern]. Bei Rückfragen: [Kontakt/DSB].

Anhang G — Incident-Report-Formular

INTERNER DATENPANNEN-REPORT (auch für nicht meldepflichtige Vorfälle - Nachweis Art. 33 (5))
Vorfall-Nr.: ... Meldende Person: ... Datum/Uhrzeit Kenntnis: ...
Beschreibung: ...
Betroffene Systeme/Daten/Personen: ...
Risikoabschätzung: [] kein Risiko [] Risiko [] hohes Risiko
Meldung Behörde nötig (72h)? [] ja [] nein - erfolgt am: ...
Benachrichtigung Betroffener nötig? [] ja [] nein - erfolgt am: ...
Sofortmassnahmen: ... Ursachenanalyse: ... Folgemaassnahmen/TOM-Anpassung: ...
Abschluss/Freigabe (GF/DSB), Datum: ...

Anhang H — Muster-Antwortschreiben Betroffenenrechte

Auskunft (Art. 15):

Sehr geehrte/r ...,
Bezug nehmend auf Ihren Antrag vom [Datum] teilen wir mit, dass wir folgende Sie betreffende
Daten verarbeiten: [Kategorien, Zwecke, Rechtsgrundlage, Empfänger, Speicherdauer, Herkunft].
Eine Kopie ist beigelegt. Sie haben zudem Rechte auf Berichtigung, Löschung, Einschränkung,
Widerspruch sowie Beschwerde bei der Aufsichtsbehörde. Für Rückfragen: [Kontakt].

Löschung (Art. 17):

Sehr geehrte/r ...,
Ihrem Loeschantrag vom [Datum] haben wir entsprochen; Ihre Daten wurden geloescht bzw.
gesperrt, soweit keine gesetzlichen Aufbewahrungspflichten (z. B. steuerrechtlich)
entgegenstehen. In diesem Fall erfolgt die Loeschung nach Fristablauf. Mit freundlichen Gruessen.

Anhang I — Checkliste Drittanbieter/AVV

- ☐ Alle Dienstleister mit Datenzugriff gelistet
- ☐ AVV vorhanden und aktuell (Art. 28)
- ☐ TOM-Anlage beigefuegt
- ☐ Subunternehmer-Liste geprueft
- ☐ Drittlandtransfer-Grundlage (DPF/SCC) dokumentiert
- ☐ Audit-/Nachweisrechte vereinbart
- ☐ Loesch-/Rueckgaberegelerung enthalten

Anhang J — Checkliste IT-Security/TOM

- ☐ Individuelle Benutzerkonten + Rollenrechte
- ☐ MFA auf E-Mail/Cloud/Google/GitHub/Buchhaltung
- ☐ Passwortmanager, Passwort-Policy
- ☐ HTTPS/TLS + HSTS; Geraeteverschluesselung
- ☐ Backups (3-2-1) + Wiederherstellungstest
- ☐ Automatische Updates (OS/CMS/Plugins/AV)
- ☐ Virenschutz/Firewall/Bildschirm Sperre
- ☐ Logging mit definierter Aufbewahrung
- ☐ Physische Sicherung (Serverraum/Akten)
- ☐ Notfall-/Wiederanlaufplan

Anhang K — To-Do-Plan mit Verantwortlichkeiten

#	Maßnahme	Verantwortlich	Aufwand	Priorität	Frist
1	Consent-Banner (Opt-in) einfuehren, GA4 daran koppeln	Marketing (David) + Web-Agentur	mittel	Hoch	0–1 Mon.
2	Datenschutzzerklaerung & Impressum aktualisieren	Marketing + Rechtspruefung	gering–mittel	Hoch	0–1 Mon.
3	MFA flaechendeckend aktivieren	IT	gering	Hoch	0–1 Mon.
4	Datenpannen-Prozess & Register etablieren	GF + IT	gering	Hoch	0–2 Mon.
5	VVT (Art. 30) erstellen	DSB/GF + alle Prozessverantwortw.	mittel	Hoch	0–3 Mon.
6	AV-Verträge einholen/prüfen	GF/Einkauf	mittel	Hoch	0–3 Mon.
7	Löschkonzept mit Fristen	DSB/Buchhaltung	mittel	Mittel	3–6 Mon.
8	TOM dokumentieren	IT	mittel	Mittel	3–6 Mon.
9	US-Transfer (DPF) dokumentieren	DSB/Marketing	gering	Mittel	3–6 Mon.
10	Mitarbeiter Schulung + Nachweis	GF/DSB	gering	Mittel	3–6 Mon.
11	Prüfung DSB-Benennungspflicht	GF	gering	Mittel	0–2 Mon.
12	Google Fonts lokal hosten	Web-Agentur	gering	Niedrig	6–12 Mon.
13	Halbjährliches internes Audit	DSB/GF	gering	laufend	fortlaufend

Anhang L — Checkliste Website-Datenschutz

- ☐ Consent-Tool aktiv (Opt-in, granular, Widerruf, Consent-Log)
- ☐ GA4 laedt erst nach Einwilligung; IP-Kuerzung; Retention gesetzt
- ☐ Google Tag Manager (falls vorhanden) consent-gesteuert
- ☐ Google Fonts lokal gehostet
- ☐ Maps/reCAPTCHA/YouTube nur nach Consent (2-Klick)
- ☐ Keine Social-Plugins ohne Consent
- ☐ Cookie-Inventar (Name/Zweck/Laufzeit/Anbieter) gepflegt
- ☐ HTTPS erzwungen + gueltiges Zertifikat + HSTS
- ☐ CSP gesetzt
- ☐ Datenschutzerklaerung deckt alle aktiven Dienste
- ☐ Impressum vollstaendig (§ 5 DDG)
- ☐ Kontaktformular: Datensparsamkeit + Datenschutzhinweis + TLS

Anhang M — Annahmenverzeichnis

ID	Annahme	Zu bestätigen durch
A1	KMU < 20 Personen mit automatisierter Verarbeitung → keine DSB-Pflicht	GF/Personal
A2	Sitz/Verarbeitung in NRW → Aufsichtsbehörde LDI NRW	GF
A3	Keine besonderen Kategorien bei Kunden; nur Beschäftigten-AU	Personal
A4	Kein Profiling / keine automatisierte Einzelentscheidung	Marketing/IT
A5	Datenschutzerklärung & Impressum grundsätzlich vorhanden, Aktualität unklar	Marketing
A6	Buchhaltung/ERP/Cloud-Speicher/Backup vorhanden, Anbieter offen	IT/Buchhaltung
A7	HTTPS auf der Website aktiv	Web-Audit (F-01)
A8	Kein Zapier/IFTTT im Einsatz	IT/Marketing
A9	Newsletter nur, falls tatsächlich betrieben	Marketing

Alle mit A1–A4 fett markierten Annahmen sind entscheidungsrelevant und vorrangig zu bestätigen.

Anhang N — 12-Monats-Roadmap

Zeitraum	Meilenstein
Monat 0–1	Consent-Banner live, DSE/Impressum aktualisiert, MFA aktiv, Datenpannen-Prozess steht
Monat 1–3	VVT fertig, AV-Verträge angefordert, DSB-Pflicht geklärt
Monat 3–6	AVV abgeschlossen, Löschkonzept & TOM dokumentiert, US-Transfer belegt, 1. Schulung
Monat 6–9	Website-Feinschliff (Fonts lokal, CSP), Bewerber-/Beschäftigten-Löschfristen umgesetzt
Monat 9–12	1. internes Audit, KPI-Review, Berichtsupdate an GF, kontinuierliche Verbesserung

Anhang O — Risiko-Dashboard

Risiko	Score	Verantwortlich	Frist	Status
R1 GA4 ohne Consent	9	Marketing/IT	0–1 Mon.	offen
R7 Kein Datenpannen-Prozess	6	GF/IT	0–2 Mon.	offen
R11 Kein MFA	6	IT	0–1 Mon.	offen
R2 Fehlende AVV	6	GF	0–3 Mon.	offen
R3 Fehlendes VVT	6	DSB/GF	0–3 Mon.	offen
R4 Veraltete DSE	6	Marketing	0–1 Mon.	offen
R5 US-Transfer undokumentiert	4	DSB	3–6 Mon.	offen
R6 Kein Löschkonzept	4	DSB	3–6 Mon.	offen
R8 TOM undokumentiert	4	IT	3–6 Mon.	offen
R10 Keine Schulung	4	GF	3–6 Mon.	offen
R12 Fehlende Löschfristen HR	4	Personal	3–6 Mon.	offen
R9 Google Fonts extern	2	Web-Agentur	6–12 Mon.	offen

Anhang P — Top-5-Sofortmaßnahmen (1-Seiter für die Geschäftsführung)

DATENSCHUTZ - TOP 5 SOFORTMASSNAHMEN (Feind GmbH)
1. Cookie-/Consent-Banner mit Opt-in einfuehren - Google Analytics erst nach Zustimmung laden. (Verhindert Abmahnrisiko; Verantwortlich: Marketing + Web-Agentur; Frist: 4 Wochen)
2. Datenschutzerklaerung & Impressum aktualisieren. (Verantwortlich: Marketing + Rechtspruefung; Frist: 4 Wochen)
3. Zwei-Faktor-Authentifizierung (MFA) fuer alle wichtigen Konten aktivieren. (Verantwortlich: IT; Frist: 4 Wochen)
4. Datenpannen-Meldeprozess (72-Stunden-Regel) + Register einfuehren. (Verantwortlich: GF/IT; Frist: 6 Wochen)
5. Verzeichnis der Verarbeitungstaetigkeiten (VVT) und AV-Vertraege starten. (Verantwortlich: GF/DSB; Frist: 8-12 Wochen)
Rechtlicher Hinweis: Muster vor Einsatz durch Rechtsabteilung/Fachanwalt pruefen lassen.

Anhang Q — Anleitung „Bericht aktualisieren“

- 1. Offene Fragen (Kap. 17) beantworten → betroffene Annahmen (Anhang M) in **Fakten** überführen.
- 2. Nach Live-Website-Audit (F-01) Kap. 12 und Anhang L/E aktualisieren.
- 3. Bei neuen Tools/Dienstleistern: VVT (Anhang A) und AVV-Liste (Kap. 7) ergänzen.
- 4. Nach jeder Maßnahme Status im Risiko-Dashboard (Anhang O) und To-Do-Plan (Anhang K) pflegen.

5. Versionsnummer/Datum im Kopf erhöhen; Änderungen kurz dokumentieren.
6. Mindestens jährlich vollständigen Review durchführen (Kap. 15).

*Ende des Berichts — Version 1.0 (Entwurf), 14.09.2026. Erstellt zur internen Verwendung.
Vor rechtsverbindlichem Einsatz der Vorlagen: Prüfung durch Rechtsabteilung / Fachanwalt für
IT-Recht.*